

炮弹休克攻击

版权所有 © 2017 杜文亮,保留所有权利。

允许个人使用。如需在课堂上使用这些习题,仅当该课程采用作者的著作作为教材时方可允许。所有其他用途均须事先征得作者的同意。

W6.1. 当包含 shell 函数定义的 shell 变量作为环境变量传递给子进程时,该函数定义会发生什么情况?

W6.2. 假设一个 Bash 程序定义了一个 shell 函数,将其导出,然后启动一个子进程,该子进程也运行 Bash。请解释一下,父 Bash 中定义的这个函数是如何成为子 Bash 中的函数的。

W6.3. 编写一个 Bash 函数定义,尝试利用 Shellshock 漏洞。

W6.4. 我们没有在函数定义后添加额外的 shell 命令,而是将其放在函数定义开头(参见以下示例)。然后我们运行 Bash,而 Bash 存在 Shellshock 攻击漏洞。shell 命令 `echo world` 会被执行吗?

```
$ export foo= echo world; () { echo hello;} $ bash
```

W6.5. 要利用 Shellshock 漏洞,需要满足两个条件。
这两个条件是什么?

W6.6. 用户输入如何以环境变量的形式进入远程 CGI 程序(用 Bash 编写)?

W6.7. 在针对 CGI 程序的 Shellshock 攻击中,除了使用函数定义之外,我们能否直接将 shell 命令放入 User-Agent 字段中,以便在触发 Bash 时执行该 shell 命令?

W6.8. ★ 为
什么会犯这个错误?你从这个错误中吸取了什么教训?

W6.9. 还有另一种向 CGI 程序发送输入的方法,那就是将输入附加到 URL 中。请参见以下示例。

```
http://www.example.com/myprog.cgi?name=value
```

我们能否将恶意函数定义放在上述 URL 的值字段中,以便当该值进入 CGI 程序 myprog.cgi 时,就可以利用 Shellshock 漏洞?

W6.10. 我们在机器 1 (IP 地址为 10.0.2.6)上运行“nc -l 7070”,然后我们输入
在机器 2 上执行以下命令。请描述将会发生什么?

```
$ /bin/cat < /dev/tcp/10.0.2.6/7070 >&0
```

W6.11. 请描述如何执行以下操作:在机器 1 上运行 /bin/cat 程序;该程序从机器 2 获取输入,并将输出打印到机器 3。

W6.12. 请考虑以下程序：

```
#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

extern char **environ;

int main() {

    char *args[] = {

        /bin/sh , -c , /bin/
        ls , NULL }; pid_t pid =

    fork();

    if(pid == 0) { /* 子进程 */
        printf( 子进程\n );
        execve(args[0], &args[0], NULL);
    }
    否则如果(pid > 0) { /* 父级 */
        printf( 父级\n );
    }

    返回 0;
}
```

该程序会派生一个子进程,并使用指向 /bin/bash 的符号链接 /bin/sh 来执行 /bin/ls 程序。程序的执行方式如下。请解释程序的输出结果以及原因。

```
$ gcc prog.c -o prog $ export foo= ()
{ echo hello; }; echo world; $ ./prog
```

W6.13. 让我们修改一下 W6.12 题中的代码。我们将第 行的代码修改为以下内容。请根据修改后的代码重新完成 W6.12 题。

```
execve(args[0], &args[0], environ);
```

W6.14. 考虑一个作为 Apache 模块运行的 PHP 程序和一个 CGI 程序。

PHP程序 (test.php) :

```
<?php
    system( /bin/ls -l )
?>
```

CGI程序 (test.cgi) :

```
#!/bin/sh /bin/
ls -l
```

这两个程序都会在一个新的 shell 进程中调用 /bin/ls 命令 (/bin/sh 指向 /bin/bash)。如果程序按以下方式调用,请解释 Shellshock 漏洞在这两种情况下的影响有何不同。在这两种情况下,利用 Shellshock 漏洞需要满足哪些条件?

```
$ curl -A () { echo hello; }; echo world; http://localhost/test.php
```

```
$ curl -A () { echo hello; }; echo world;
http://localhost/test.cgi
```